

Phase 1 — Final Verification Report

Verification of the approved Phase 1 baseline before any SaaS conversion. Includes code checks, automated tests, production build, and local smoke QA.

Document type	Phase 1 final verification & smoke QA
Date	17 September 2026
Automated tests	26 passed, 0 failed
TypeScript	<code>npx tsc --noEmit</code> — exit 0
Production build	<code>npm run build</code> — exit 0
Final status	PASS WITH REMAINING ISSUES

Contents

Phase 1 implementation summary
Verification results
Security verification
Functional smoke test results
Automated test results
TypeScript check
Production build result
UI/UX verification
Bugs fixed
Remaining issues
Known limitations
Changes intentionally deferred to Phase 2
Final Phase 1 status
Recommended next step

Phase 1 implementation summary

This document is the final verification of the approved Phase 1 baseline for the current single-tenant RedKnot Rent-a-Car Management System. SaaS conversion was not started. No Company/tenant model, companyId, subscriptions, Google OAuth, email verification, or global blacklist work was added. The Prisma schema was not changed.

- Employee/Staff cannot cancel rentals. cancelRental requires rentals.cancel (ADMIN and SUPER_ADMIN only).
- Drivers cannot open hire record pages or hire receipts by changing the URL. Settlement PDFs require settlements.view.
- Staff can view and create expenses. Staff cannot edit or delete. Administrators can edit and delete.
- /api/health in this codebase returns only { status: "ok" }.
- Broadcast notification read state is per-user via BROADCAST_READ receipt rows. No schema migration.
- Currency display uses Settings currency_symbol. Financial formulas were not changed.
- All 17 sidebar items, the Rentals MAIN badge, desktop sidebar, and mobile tab bar remain.

Phase 1 code is present in the local workspace and was verified against a local production build (next start). It has not yet been deployed to Vercel. The live Vercel /api/health response still matches the old implementation.

Verification results

Employee cannot cancel	PASS — rentals.cancel absent for EMPLOYEE; cancelRental uses rentals.cancel; automated test passed.
Administrator can cancel	PASS — ADMIN and SUPER_ADMIN have rentals.cancel. Live Cancel button was not clickable because the current dataset has no open (non-completed) rentals.
Driver unauthorized rental records	PASS — middleware blocks DRIVER from /rentals/* except /rentals; hire detail uses requireNonDriver.
Driver unauthorized receipts	PASS — HTML and PDF require rentals.receipt; DRIVER does not have it.
Settlement receipt authorization	PASS — owner and broker PDF routes require settlements.view only.
Staff create expenses	PASS — EMPLOYEE has expenses.view and expenses.create; /expenses/new exists.
Staff cannot edit/delete expenses	PASS — no expenses.edit/delete for EMPLOYEE; updateExpense/deleteExpense require those permissions.
Administrator edit/delete expenses	PASS — live admin expense detail showed Edit and Delete; /expenses/[id]/edit is in the production build.
Health endpoint (this build)	PASS — local http://localhost:3000/api/health returned {"status":"ok"} with no checks object.

Broadcast read per-user	PASS — notification service writes per-user BROADCAST_READ receipts; automated overlay tests passed.
Currency symbol	PASS — formatCurrency uses Settings currency_symbol; dashboard amounts displayed with Rs. from settings.
Sidebar 17 items	PASS — live desktop sidebar listed all 17 items in original order.
Rentals MAIN badge	PASS — expanded sidebar showed “Rentals Main”.
Desktop sidebar	PASS — present, collapsible, used during smoke test.
Mobile navigation	PASS — bottom tab bar (Dashboard, Rentals, Customers, Vehicles, More) present on the local build.
Business calculations unchanged	PASS — pricing/commission/deposit unit tests still pass with original expected values.
Rental workflow intact	PASS — rental pages, receipt, refund-deposit, ending-odometer routes remain in the production build.

Security verification

Checks were made against source, unit tests, and a local production server. Direct URL/API behaviour for DRIVER/EMPLOYEE was verified in code and tests. Live multi-role browser follow-through after administrator sign-out was blocked by AUTH_URL pointing at the production host (environment configuration, not a Phase 1 code change).

Direct access — expected enforcement

- DRIVER /rentals/[id], /rentals/[id]/receipt, /rentals/[id]/refund-deposit: middleware canAccessRoute returns false and redirects home.
- DRIVER GET /api/rentals/[id]/receipt: requirePermissionApi(rentals.receipt) != 403.
- DRIVER GET /api/settlements/owner|broker/[id]/receipt: requirePermissionApi(settlements.view) != 403.
- EMPLOYEE cancelRental: requirePermission(rentals.cancel) redirects/fails; UI Cancel only if canCancel.
- EMPLOYEE /expenses/[id]/edit: page requirePermission(expenses.edit) redirects home. Middleware allows the URL because expenses.view exists; the page and server action still block.
- EMPLOYEE updateExpense / deleteExpense: require expenses.edit / expenses.delete.
- EMPLOYEE /users, /reports, /settings, /audit: middleware canAccessRoute false.
- Unauthenticated pages: middleware redirects to /login.
- Customer documents: still require customers.view, but any such user can fetch any document id (single-tenant IDOR). Not changed in Phase 1.

Live production (Vercel) note

The deployed Vercel app is still the previous Git commit (mobile tab bar). GET /api/health on the live nine.vercel.app host still returns a checks object including whether the auth secret is set, the public auth URL, Vercel flag, and database connected/disconnected. That leak is fixed in local Phase 1 code and will disappear only after this baseline is deployed. No secret values are reproduced in this report.

Functional smoke test results

Local production server: next start on localhost after a successful next build. Logged in as company SUPER_ADMIN. Invalid login showed “Invalid email or password”. Valid login opened the dashboard with live operational figures.

Login	PASS — invalid rejected; valid administrator session opened dashboard.
Dashboard	PASS — pipeline, fleet, revenue/expense, alerts loaded. Currency Rs.
Customers	PASS — Customer Management 200.
Vehicles	PASS — Vehicle Management 200.
Owners	PASS — Vehicle Owner Management 200.
Drivers	PASS — Driver Management 200.
Brokers	PASS — Broker Management 200.
Rentals	PASS — Rental Management 200; hire detail RK-2026-00009 opened; receipt HTTP 200 for administrator.
Payments	PASS — Payment Management 200.
Damages	PASS — Damage Management 200.
Settlements	PASS — Settlements & Commissions 200.
Maintenance	PASS — Maintenance Management 200.
Expenses	PASS — list 200; Record Expense 200; administrator detail showed Edit and Delete.
Reports	PASS — Reports & Profitability 200.
Notifications	PASS — Notification Center 200.
Audit Log	PASS — Audit Log 200.
Settings	PASS — System Settings 200.
Users	PASS — User Management 200 for SUPER_ADMIN.

Employee and Driver click-through was not completed in the browser after Sign Out, because NextAuth used the configured production AUTH URL and sent the browser to the live Vercel login. Those roles were verified by permission tests and server-side guards instead. No business data was created or deleted during this smoke test.

Automated test results

Command: npm test

Result: 26 passed, 0 failed, 0 skipped. Suites: role permissions (Employee cancel, expenses, Driver receipts/URLs), rental days, pricing, balance, broker commission, owner settlement, vehiclePaysAnOwner, deriveOwnerRatesFromCustomerRates, broadcast notification read overlay, rental cancel transitions, security deposit remaining, currency display.

TypeScript check

Command: `npx tsc --noEmit`. Result: exit code 0. No type errors reported.

Production build result

Command: `npm run build` (Next.js 16.3.1 Turbopack). Result: exit code 0. Compiled successfully. TypeScript finished. Static generation 3/3. All app routes are dynamic (force-dynamic), including `/expenses/[id]/edit`, `receipts`, and `health`.

- Warning (non-blocking): Next.js reports the middleware file convention is deprecated in favour of “proxy”. This was not changed in Phase 1.
- No build errors.
- Local runtime: next start Ready; `/api/health` returned `{"status":"ok"}` only.

UI/UX verification

- Sidebar structure preserved. Items: Dashboard, Customers, Vehicles, Owners, Drivers, Brokers, Rentals, Payments, Damages, Settlements, Maintenance, Expenses, Reports, Notifications, Audit Log, Settings, Users.
- Rentals MAIN badge present when the sidebar is expanded.
- Desktop sidebar works (collapse/expand).
- Mobile bottom navigation works (primary tabs + More).
- Visual grouping Operations / Finance / System does not relocate items.
- Tables and cards use quieter commercial styling; dashboard pulse animations are disabled.
- Login copy is professional; seeded credentials are not shown on the local Phase 1 login page.
- Empty states remain (example: no active rentals on the dashboard).
- No obvious layout breakage on the administrator dashboard or module list pages.
- Onboarding tour still exists and can be skipped; it is optional, not a daily-work animation.

Bugs fixed

- Employee could cancel via `rentals.edit`.
- Broadcast mark-read updated a shared `isRead` flag for every user.
- `/api/health` exposed environment and database status (fixed in this codebase; not yet live on Vercel).
- Login page showed seeded credentials (fixed in this codebase).
- Driver could open hire receipts and settlement PDFs with `rentals.view`.
- Administrators had no expense edit/delete path.
- Currency labels ignored Settings `currency_symbol`.

Remaining issues

- Phase 1 is not deployed to Vercel yet. Live health still returns the old checks object.
 - DRIVER can still see the rentals list and dashboard (company-wide). Record pages and receipts are blocked until User!“Driver linking.
 - Customer document files: any customers.view user can fetch any document id.
-

- JWT role/status can stay stale until idle timeout or session max age.
- Local uploads remain ephemeral on Vercel.
- Booking/payment/expense codes still use count()+1 and can race.
- No login rate limit or lockout.
- users.create can still assign SUPER_ADMIN (only SUPER_ADMIN has that permission today).
- Local next start Sign Out followed the configured production AUTH URL, which interrupted in-browser Employee/Driver follow-through. This is environment configuration, not a product workflow bug.
- No open rentals currently exist to click Cancel in the UI (all sampled hires are completed).

Known limitations

This remains a single-tenant system. Users who share a permission can still open any record in that module by id. That is current product behaviour and is not multi-tenant isolation. Frontend hiding is backed by server requirePermission on pages and actions reviewed in Phase 1, with the remaining holes listed above.

Changes intentionally deferred to Phase 2

- Company / tenant / companyId.
- Platform Super Admin UI and separate platform sidebar.
- Company Owner / Staff role rename beyond the current SUPER_ADMIN / ADMIN / EMPLOYEE / DRIVER matrix.
- Subscriptions, grace period, configurable annual pricing.
- Google login, email verification, password reset.
- Global NIC blacklist.
- S3/R2 file storage.
- Per-company branding.
- Driver user account linked to Driver master for assigned-hire scope.
- Replacement of Next.js, Prisma, NextAuth, or UI libraries.

Final Phase 1 status

PHASE 1 FINAL STATUS: PASS WITH REMAINING ISSUES

Reason: The approved Phase 1 implementation is present in the workspace, typechecks, passes all 26 automated tests, builds, and runs locally. Administrator smoke of every major module succeeded. Health is locked down in this build. Sidebar, MAIN badge, and mobile navigation are intact. Formulas were not changed. Remaining issues are either pre-existing single-tenant limitations, items explicitly deferred to Phase 2, or the fact that this baseline has not been deployed to Vercel yet. Nothing in this verification failed the approved Phase 1 scope.

Recommended next step

- Review this verification report.
 - Commit and deploy the Phase 1 baseline with a Git author that Vercel Hobby will accept, then re-check live /api/health returns only {"status":"ok"}.
 - Optionally smoke Employee and Driver on the deployed host after that release.
-

- Create a git checkpoint tagged as the stable single-tenant baseline.
- Only after your approval, begin Phase 2 SaaS conversion.

Phase 2 has not been started. This report contains no passwords, API keys, tokens, or secret environment values.

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

Prepared 17 Sep 2026 · Status: PASS WITH REMAINING ISSUES · SaaS not started

